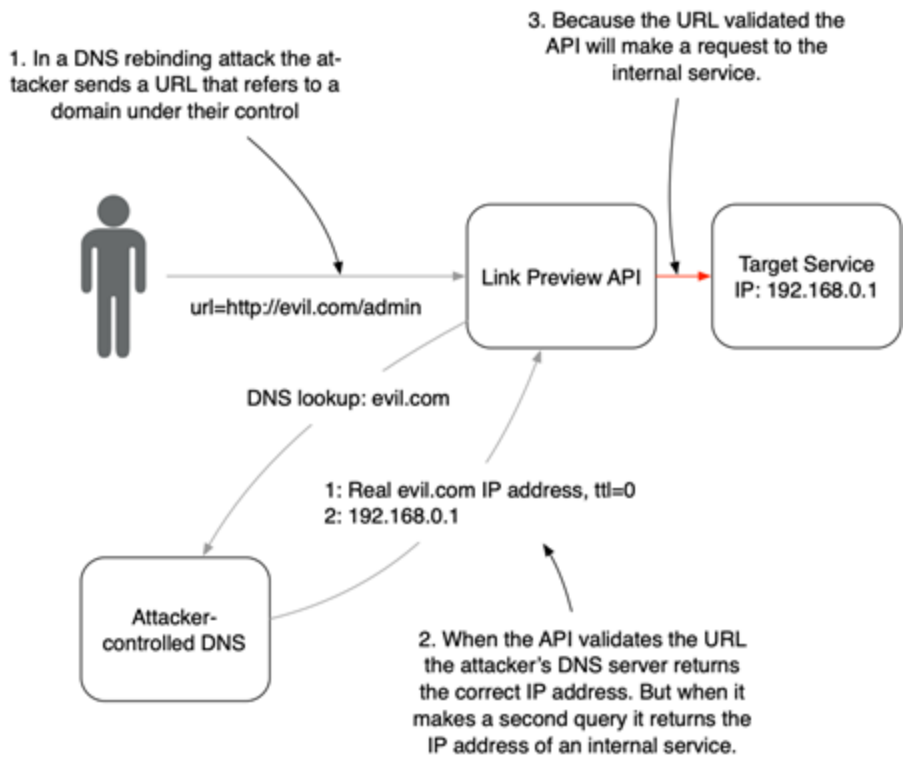


Figure 10.5 In a DNS rebinding attack the attacker submits a URL referring to a domain under their control. When the API performs a DNS lookup during validation the attacker's DNS server returns a legitimate IP address with a short time-to-live (ttl). Once validation has succeeded the API performs a second DNS lookup to make the HTTP request and the attacker's DNS server returns the internal IP address, causing the API to make an SSRF request even though it validated the URL.

While it is hard to prevent DNS rebinding attacks when making an HTTP request, you can prevent such attacks against your APIs in several ways:

- Strictly validating the Host header in the request to ensure that it matches the hostname of the API being